

PicoCTF 2026 – Old Sessions

Old Sessions

Web Exploitation **Easy** 100 pts 9,815 solves

by David Gaviria

Proper session timeout controls are critical for securing user accounts. If a user logs in on a public or shared computer but doesn't explicitly log out (instead simply closing the browser tab), and session expiration dates are misconfigured, the session may remain active indefinitely. This then allows an attacker using the same browser later to access the user's account without needing credentials, exploiting the fact that sessions never expire and remain authenticated.

In this challenge, we are told about misconfigured web apps that don't delete user sessions when the user logs out

PicoCTF 2026 – Old Sessions

Non-Expiring Cookies

mary_jones_8992

Hey I found a strange page at **/sessions**

After registering a user and logging in, we see a message from a user mentioning a /sessions endpoint

PicoCTF 2026 – Old Sessions

Non-Expiring Cookies

```
session:3qnyBBRYpsrOk2GS1Y1AuxYRr8
```

```
{'_permanent': True, 'key': 'admin'}
```

Name	Value
session	3qnyBBRYpsrOk2GS1Y1AuxYRr8...

On that page, there are session values that can be put into cookies

PicoCTF 2026 – Old Sessions

Non-Expiring Cookies

Homepage

Welcome *admin*

Logout

picoCTF{*admin_session_expiration5_51d7031a*}

So we can hijack the session by pasting the admin session value into our cookie